Методы и принципы проектирования современных защищённых систем

Лекция 1

Проектирование защищённых систем

Активы · границы доверия · нарушитель · угрозы · требования

План лекции


1
Свойства и принципы
2
Активы и поверхность атаки
3
Границы доверия
4
Нарушитель и угрозы
5
Нулевое доверие
6
Требования безопасности

1

Свойства и принципы

что защищаем и по каким правилам

Три свойства безопасности

Конфиденциальность

не раскрывается неуполномоченным

Целостность

информация точна и полна

Доступность

доступна по запросу уполномоченного

Неотказуемость

действие нельзя позднее отвергнуть

Подлинность

субъект или ресурс — именно тот, что заявлен

Одна уязвимость — несколько свойств

Конфиденциальность

похищены данные многих организаций

Целостность

в систему добавлены скрытые учётные записи

Доступность

организации отключали сервис

Пример: SQL-инъекция в MOVEit Transfer, 2023 год

Восемь принципов проектирования

Экономия механизма

механизм прост и мал

Отказ по умолчанию

запрещено всё, что не разрешено явно

Полное посредничество

каждое обращение проверяется

Открытый замысел

секретен только ключ

Разделение привилегий

критичное — с согласия нескольких

Наименьшие привилегии

только необходимые права

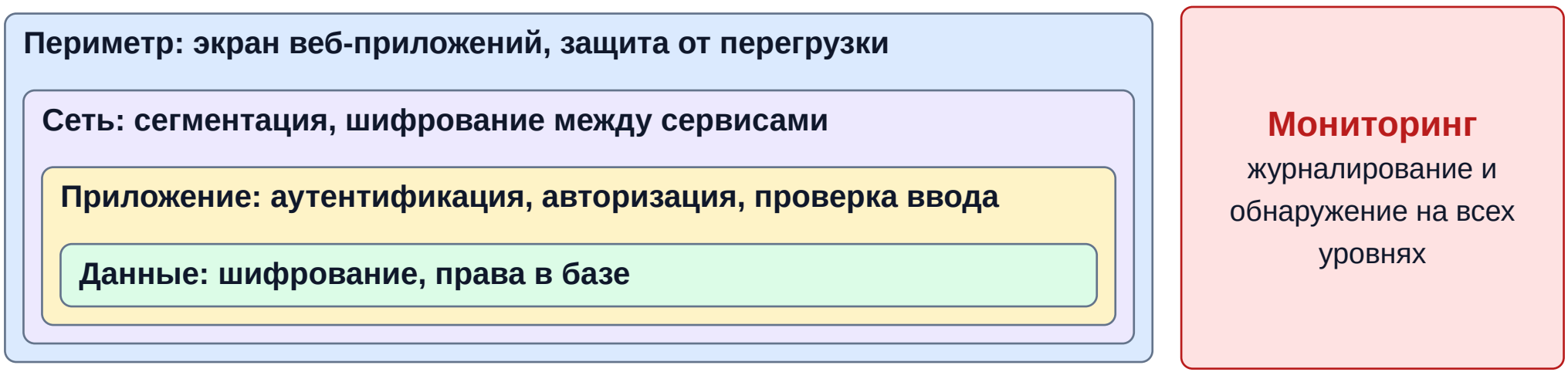
Наименьший общий механизм

минимум общих средств

Психологическая приемлемость

защиту просто применять

Защита в глубину



Отказ одного уровня не приводит к полному взлому

Принципы нарушаются в реальных инцидентах

Инцидент	Нарушенный принцип	Что произошло
Capital One, 2019	Наименьшие привилегии	Роль с избыточным доступом к хранилищу: скопированы данные около 100 млн человек
SolarWinds, 2020	Разделение привилегий	Закладка в среде сборки: обновление получили порядка 18 тысяч организаций
Log4Shell, 2021	Экономия механизма	Библиотека журналирования выполняла поиск по внешним каталогам внутри строки

2

Активы и поверхность атаки

что защищаем и где можно напасть

Активы учебного магазина

Данные покупателей

важно: конфиденциальность

Платёжные операции

важно: целостность и конфиденциальность

Ключ платёжного сервиса

важно: конфиденциальность

Каталог и цены

важно: целостность

Работа сайта

важно: доступность

Поверхность атаки: два нарушителя

Внешний нарушитель

Точки входа
службы из интернета, электронная почта, сторонние библиотеки, сотрудники

Способы проникновения
уязвимость публичной службы, подбор паролей, инъекции, фишинг, закладка в зависимости

Внутренний нарушитель

Точки входа
рабочие места, административные панели, базы данных, носители

Способы проникновения
злоупотребление правами, повышение привилегий, вынос данных, физический доступ

Внешний ищет точку входа, внутренний выходит за пределы выданных прав

Сокращение поверхности атаки

1 Перечислить точки входа → **2** Классифицировать → **3** Сократить лишнее → **4** Пересматривать каждый выпуск

- отладочные входы — удалить
- единый шлюз вместо десятков входов
- сетевые политики: только нужные пары

3

Границы доверия

где меняется уровень доверия

Типичные границы доверия

Клиент → сервер

шифрование TLS, проверка токена и ввода

Сервис → сервис

взаимная аутентификация, права, параметры запросов

Внешняя система → наша

ключ или OAuth, ограничение частоты

Сборка → рабочая среда

подпись артефактов, политики допуска

Пользователь → администратор

второй фактор, полный аудит

Облако → локальная сеть

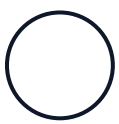
VPN или доступ с проверкой личности

Элементы диаграммы потоков данных



Внешняя сущность

пользователь или внешняя система



Процесс

компонент, обрабатывающий данные



Хранилище

база данных, файлы, кэш



Поток данных

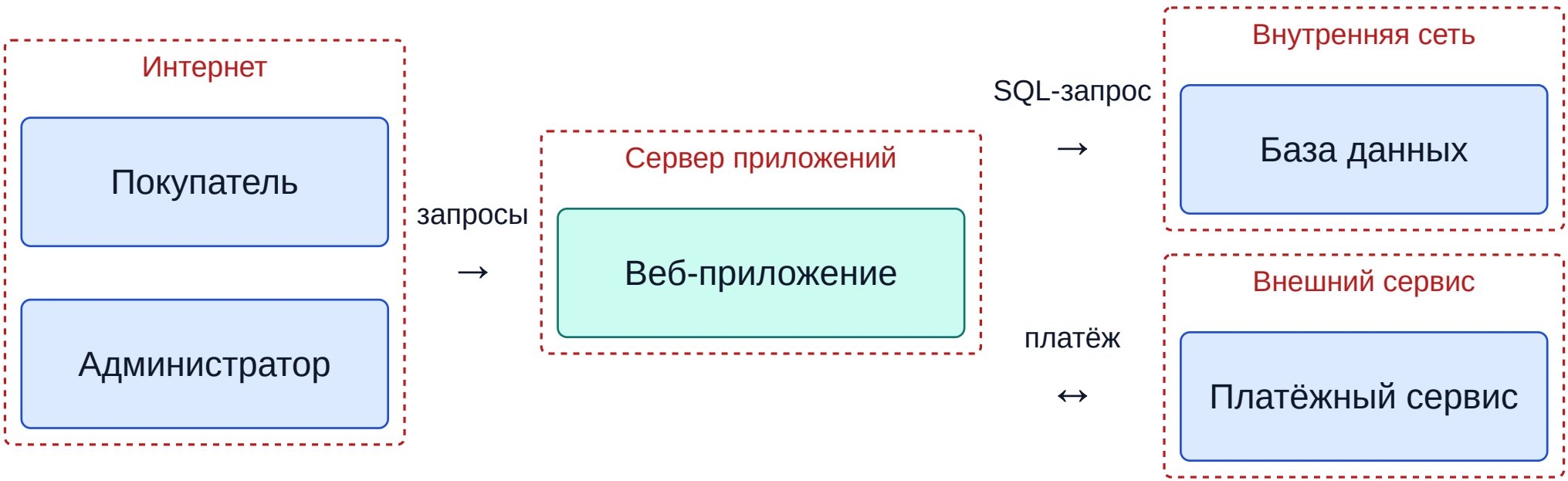
передача данных между элементами



Граница доверия

место смены уровня доверия

Диаграмма потоков данных магазина



Три границы доверия и четыре потока — здесь ищем угрозы

4

Нарушитель и угрозы

кто и как может атаковать

Типовые нарушители

Начинающий

любопытство; готовые средства

Активист

идеология; перегрузка, публикация данных

Преступная группа

выгода; вымогатели, мошенничество

Государственная группировка

шпионаж; неизвестные уязвимости

Внутренний нарушитель

месть, выгода; вынос данных

Невнимательный сотрудник

нет умысла; ошибки настройки

Потенциал нарушителя: H1–H4

H1
Базовый

готовые средства и общеизвестные уязвимости

H2
Базовый повышенный

изменяет готовые средства, комбинирует уязвимости

H3
Средний

ищет уязвимости и создаёт собственные средства

H4
Высокий

внедряет закладки, ресурсы организации или государства

Цепочка целевой атаки



Этапы атаки и тактики ATT&CK

Этап	Тактика	Пример техники	Обнаружение
Разведка	Reconnaissance (TA0043)	Active Scanning (T1595)	Журналы экрана веб-приложений
Доставка	Initial Access (TA0001)	Phishing (T1566)	Почтовый шлюз, второй фактор
Эксплуатация	Execution (TA0002)	Command and Scripting Interpreter (T1059)	Защита конечных точек
Закрепление	Persistence (TA0003)	Scheduled Task/Job (T1053)	Аудит системы
Управление	Command and Control (TA0011)	Application Layer Protocol (T1071)	Анализ DNS и прокси
Достижение цели	Exfiltration (TA0010)	Exfiltration Over C2 Channel (T1041)	Контроль утечек

STRIDE: шесть типов угроз

S
Подмена личности

нарушает подлинность

T
Изменение данных

нарушает целостность

R
Отказ от действия

нарушает неотказуемость

I
Раскрытие информации

нарушает конфиденциальность

D
Отказ в обслуживании

нарушает доступность

E
Повышение привилегий

нарушает авторизацию

Какие угрозы применимы к каким элементам

Элемент	S	T	R	I	D	E
Внешняя сущность	✓		✓			
Процесс	✓	✓	✓	✓	✓	✓
Хранилище данных		✓	✓*	✓	✓	
Поток данных		✓		✓	✓	

* только хранилища журналов

Угрозы учебного магазина

№	Элемент	Тип	Сценарий
У1	Веб-приложение	S	Подбор пароля покупателя на странице входа
У2	База данных	T, I	SQL-инъекция через форму поиска
У3	Веб-приложение	I, E	Подстановка номера чужого заказа
У4	Веб-приложение	D	Поток запросов к странице входа
У5	Администратор	R	Отрицает смену цены товара
У6	Платёжный запрос	T	Изменение суммы в запросе к платёжному сервису

Ранжирование по риску

Вероят-ность	Воздействие 1	Воздействие 2	Воздействие 3
3		У1	У3
2		У4	У2
1		У5	У6

1–2 · низкий	3–4 · средний	6–9 · высокий

5

Нулевое доверие

каждое обращение проверяется

Периметр и нулевое доверие

Аспект	Периметровая модель	Нулевое доверие
Доверие	Внутри сети — доверенный	Никто не доверен по умолчанию
Проверка	Вход в сеть	Каждое обращение
Сегментация	Сети и межсетевые экраны	Мелкая, по идентичности
Перемещение внутри	Свободное	Каждый переход проверяется
Слабость	Один взлом открывает всё	Сложность внедрения

Семь положений NIST SP 800-207

1

Всё — ресурсы

2

Весь обмен защищён независимо от сети

3

Доступ — на один сеанс

4

Динамическая политика по контексту

5

Контроль состояния устройств

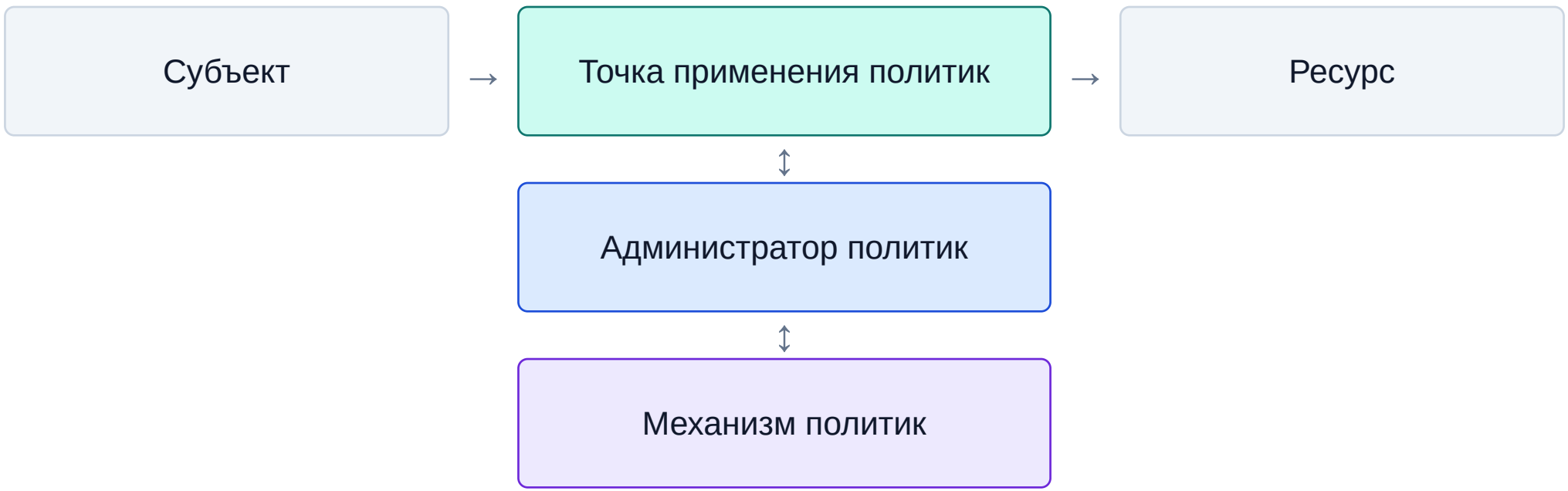
6

Проверка до доступа, а не после

7

Сведения об обмене улучшают защиту

Компоненты нулевого доверия



Механизм решает, администратор выполняет, точка применения пропускает или блокирует

Нулевое доверие в магазине

№	Угроза	Как закрывается
У3	Доступ к чужим заказам	Каждое обращение к заказу проверяет владельца
У5	Отрицание изменения цены	Второй фактор и запись действия в журнал
У2	SQL-инъекция	Приложению выданы только необходимые права в базе данных
У6	Подмена суммы платежа	Платёжный сервис принимает только подписанные запросы

6

Требования безопасности

угроза превращается в проверяемое требование

Источники требований

Бизнес и договоры

защита платёжных данных, соглашения об уровне услуг

Отраслевые стандарты

OWASP ASVS, ISO 27001, NIST CSF, CIS Controls

Моделирование угроз

мера, проверка и метрика для каждой угрозы

Внутренние политики

доступность, сроки хранения, реагирование

OWASP ASVS 5.0

≈ 350

требований

17

глав

3

уровня проверки

Уровень 1	Уровень 2	Уровень 3
любые приложения	приложения с конфиденциальными данными	критические системы: медицина, финансы

Уровни накопительные: третий включает первый и второй

Хорошее требование безопасности

Конкретно	Проверяемо	Прослеживаемо	Измеримо
блокировка после 5 неудач за 15 минут	6 неверных попыток — блокировка	У1: подбор пароля (S)	число блокировок в сутки

> Событие журнала: auth.lockout

Девять шагов моделирования угроз



Итоговая таблица учебного магазина

Угроза	Риск	Мера	Проверка	Событие
У1 Подбор пароля	Высокий	Второй фактор, ограничение частоты	6 попыток → блокировка	`auth.lockout`
У2 SQL-инъекция	Высокий	Запросы с параметрами, экран веб-приложений	Статический анализ, sqlmap	`waf.block.sqli`
У3 Чужие заказы	Высокий	Проверка владельца заказа	Чужой заказ → 403	`authz.denied`
У4 Отказ в обслуживании	Средний	Ограничение частоты, сеть доставки	Нагрузочный тест	`rate.exceeded`
У5 Смена цены	Низкий	Журнал с защитой от изменения	Запись с автором	`admin.price_change`
У6 Сумма платежа	Средний	Подпись запроса, сверка суммы	Изменённая сумма → отказ	`payment.mismatch`

Главное

1 Свойства и принципы	Три свойства, восемь принципов, защита в глубину
2 Активы и поверхность	Защищаем активы, сокращаем точки входа
3 Границы доверия	Проверяем там, где меняется доверие
4 Нарушитель и угрозы	Кто, как, насколько опасно: STRIDE и риск
5 Нулевое доверие	Каждое обращение проверяется
6 Требования	Угроза → мера → проверка → событие

Методы и принципы проектирования современных защищённых систем

Лекция 1

Проектирование защищённых систем

Активы · границы доверия · нарушитель · угрозы · требования